

Cross-Wallet PID Issuance via App Clip

How any wallet obtains a formally-verified Person Identification Datum (PID) by launching the standalone **PID Capture** companion (a full app or an install-free App Clip) that reads an eMRTD passport chip over NFC and confirms a live human with iProov Genuine Presence Assurance — with the credential minted straight back into the wallet that started the flow, bound to that wallet's own key.

Scope: the shipped capture-session backend, the companion app/App Clip, and the cross-wallet correlation that routes the issued PID to the requesting wallet. · **Issuer:** `issuer.advatar.systems` · **Capture host:** `pid.advatar.systems` · **Credential:** German PID, SD-JWT VC (`dc+sd-jwt`).

1 · At a glance

PID Capture decouples **who proves the identity** from **who holds the credential**. A wallet that cannot itself read a passport chip — a thin wallet, an App-Clip-only experience, or a wallet on another device — opens a short-lived **capture session** bound to its own proof-of-possession key. The companion performs the sensitive capture (liveness + chip), the issuer validates it authoritatively, and the resulting PID is bound to the requesting wallet's key. The companion never holds the credential and never sees a signing key.

1. Bind

The wallet generates a P-256 holder key and opens a session; the PID will be bound to that key's `cnf`.

2. Capture

A universal link / App Clip launches PID Capture: iProov liveness, then a chip read over the `service-nfc` relay.

3. Issue

VCIssuer re-runs Passive Authentication + validates liveness, then mints the PID and hands it back to the wallet.

Components

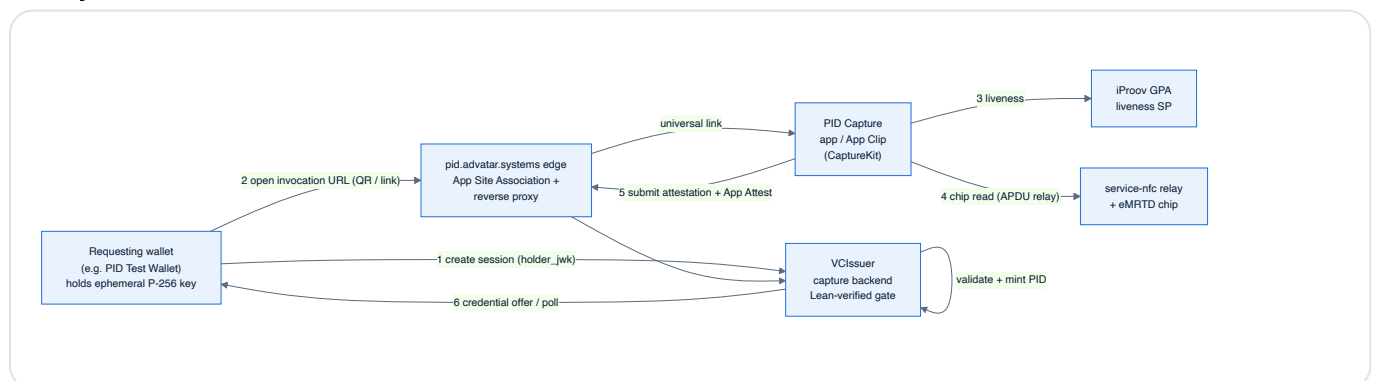


Figure 1. Component map. The `pid.advatar.systems` edge serves the Apple App Site Association (so the link opens the app) and proxies the capture API to the issuer.

2 · End-to-end sequence

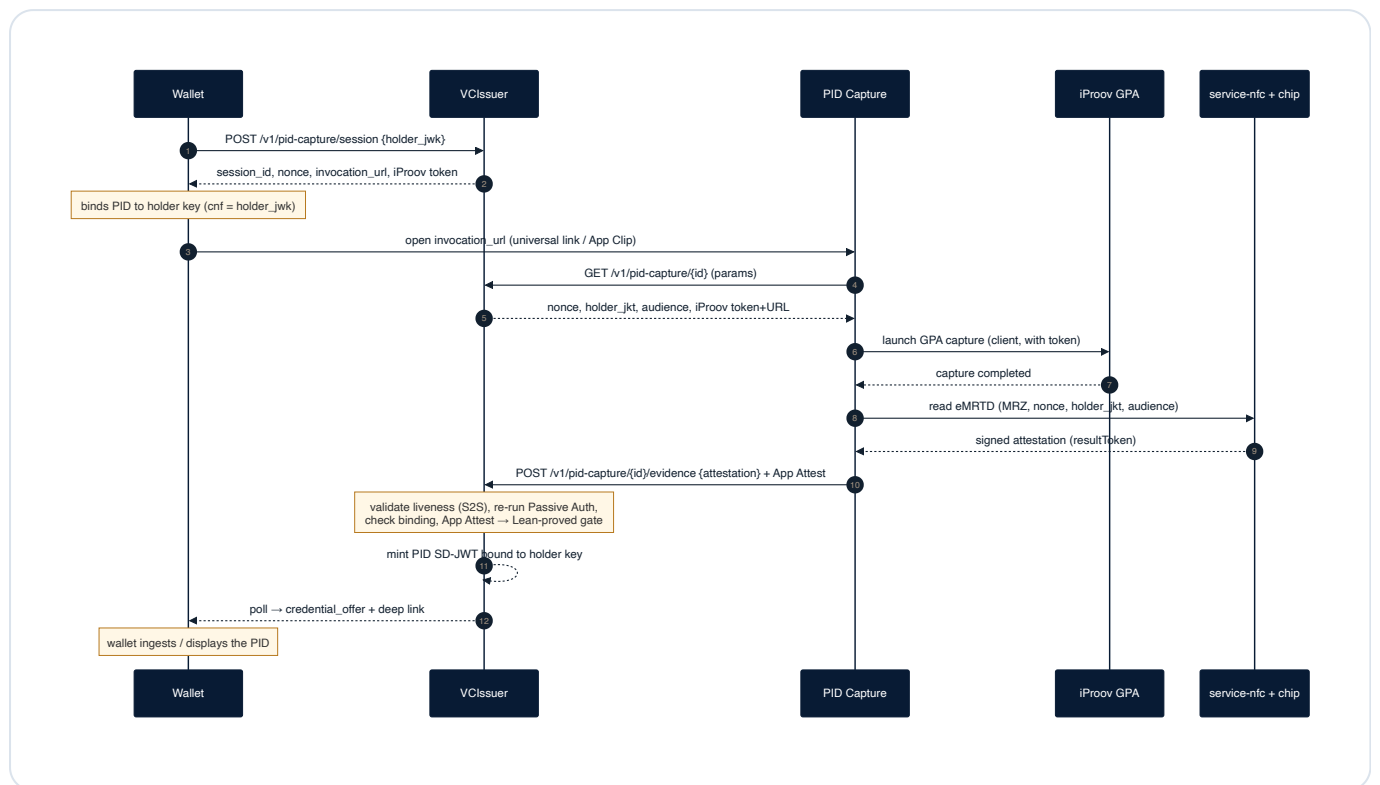


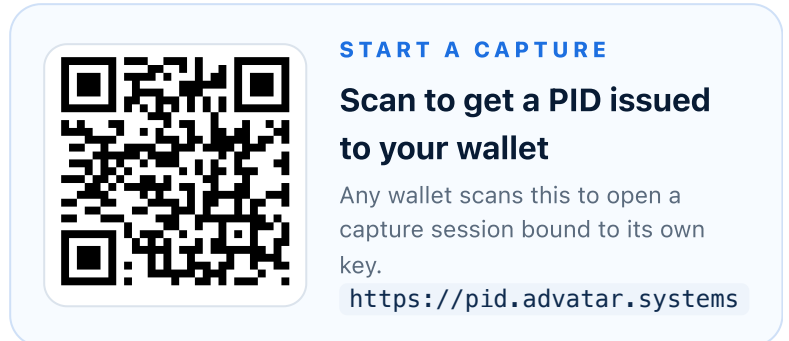
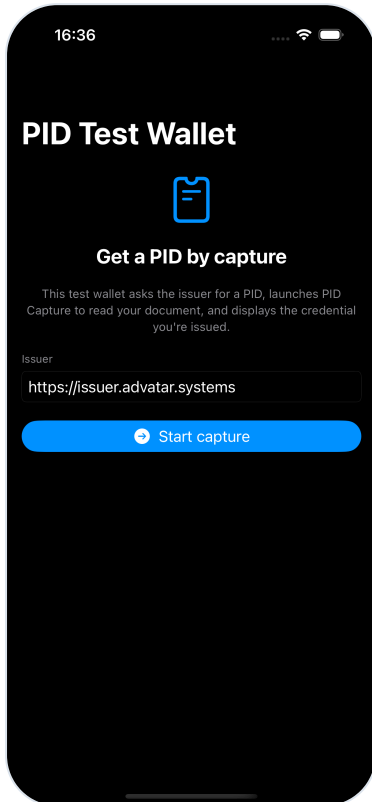
Figure 2. The full capture-to-credential sequence. Steps mirror `CaptureCoordinator.run` (liveness before chip) and the `/v1/pid-capture` handlers in the issuer service.

Why this shape? The wallet registers its key *first*, so the PID is bound to the wallet by construction — there is no redirect chain carrying a bearer credential. The companion only ever produces *evidence*; the issuer makes the authoritative decision and is the only party that can sign.

3 · Walkthrough with screens

■ Live screenshot ■ Representative UI mockup (device-only screen)

Step 1 — Start from any wallet LIVE

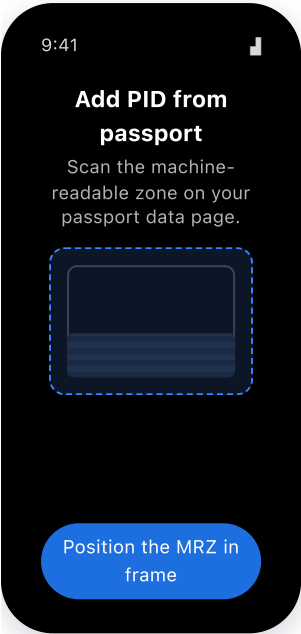


VCIssuer landing QR. Reproduced from the WebIssuer *PID Capture* section; the code encodes `https://pid.advatar.systems`.

PID Test Wallet. A minimal reference wallet: it creates a key-bound session, launches PID Capture, and displays the PID it receives. It stores nothing.

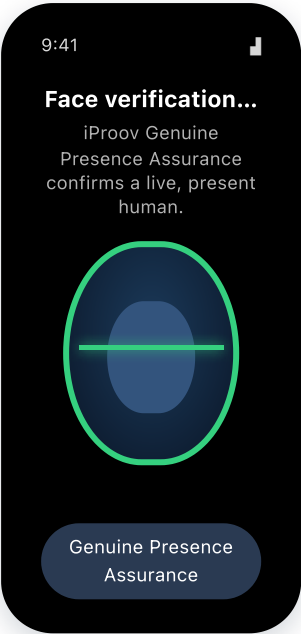
Step 2–6 — Inside PID Capture

REPRESENTATIVE MOCKUPS



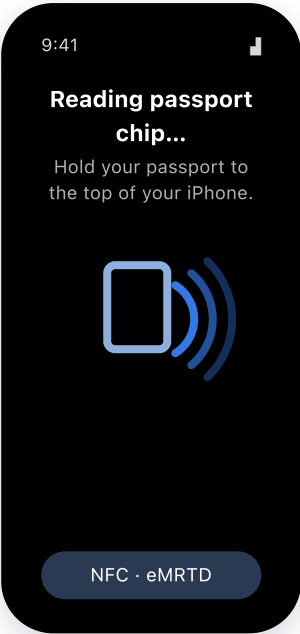
MRZ scan

camera reads the data page



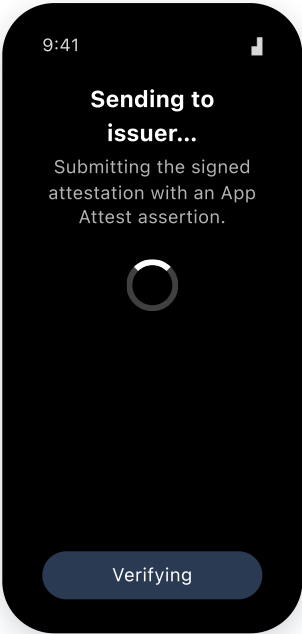
iProov liveness

flashing GPA scan



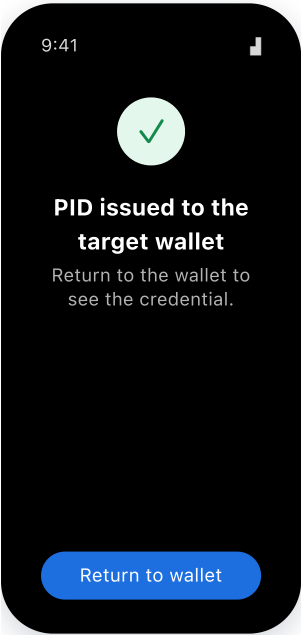
NFC chip read

relayed to service-nfc



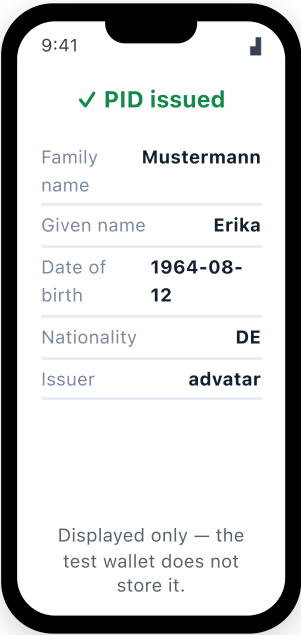
Submit

evidence to VCIssuer



Issued

hand back via deep link



Wallet displays PID

bound to its key

Note on the device screens. PID Capture runs only on a physical iPhone — iProov’s liveness SDK and CoreNFC are unavailable in the iOS Simulator — so the six screens above are faithful **representative mockups** built from the app’s exact on-screen copy. Only the home screen (Step 1, left) and the QR are live output.

4 · Backend NFC — reading the passport chip

The passport's contactless chip is an **eMRTD** (ICAO 9303). PID Capture uses the `ChipmunkNFC` SDK, which drives CoreNFC on the phone but runs the eMRTD protocol through the **service-nfc WebSocket relay** (`wss://nfc.dev-eu.iproov.id/channel`). The phone is the radio bridge; the cryptographic session and the document's authenticity checks are handled server-side and returned as a **signed attestation**.

What the read includes

- **Access** — BAC/PACE derived from the MRZ (passport number, DOB, expiry).
- **DG2 portrait** — the chip's facial image (`skipDG2: false`).
- **Passive Authentication** (`doPA`) — verifies the Document Security Object signature chains to a CSCA.
- **Active Authentication** (`doAA`) — challenge–response proving the chip is genuine, not cloned.

The binding

The relay welds the VCIssuer session context — **session nonce**, **target holder-key thumbprint**, and **audience** — into the signed `resultToken` it returns. That ties this specific chip read to this specific capture session and this specific wallet, so evidence cannot be replayed or re-pointed at another wallet.

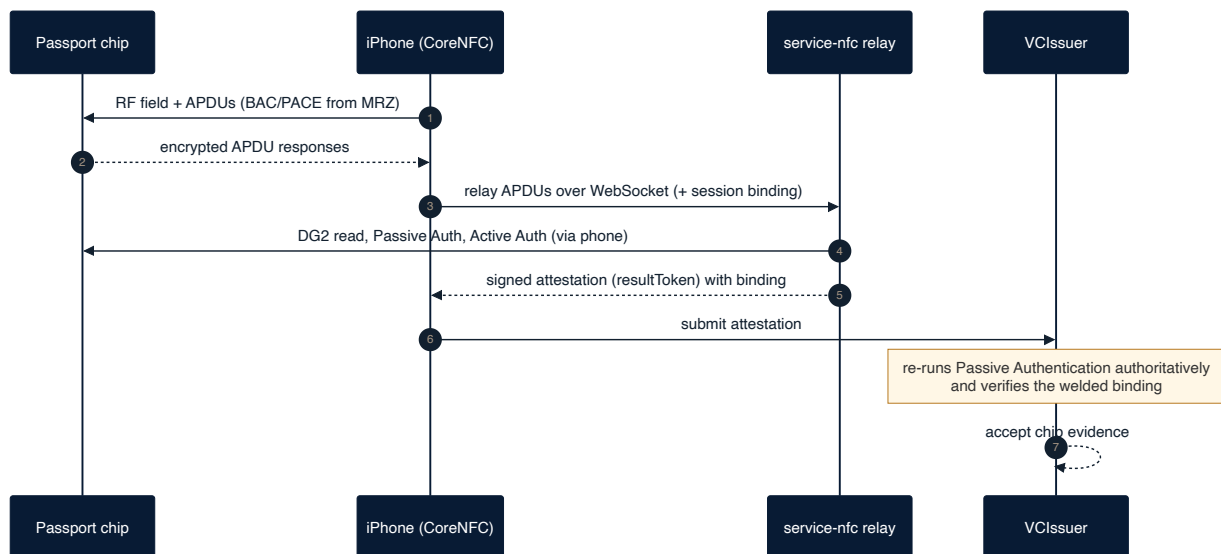


Figure 3. Backend NFC. The phone bridges RF; the relay drives the eMRTD session and signs the result; VCIssuer re-verifies Passive Authentication itself — the client is never trusted to decide.

5 · iProov liveness — proving a live human

Before the chip read, PID Capture runs an **iProov Genuine Presence Assurance (GPA)** capture: a brief, screen-illuminated face scan that proves the user is a real, present person — not a photo, mask, or replay — and binds that live face to the capture session. VCIssuer mints the iProov verify token **server-to-server** when the session opens, so the client never chooses its own liveness parameters.

Authoritative at the issuer

The SDK reports only whether the capture *completed*. The authoritative pass/fail is decided by VCIssuer validating the result against iProov's API — **downgrade-closed**: if the liveness provider is unconfigured or unreachable, issuance fails rather than proceeding without proof.

Order matters

Liveness runs *first*, while the user is already holding the phone up to their face, and the chip read follows. Both are required; a session that is missing its iProov token is rejected before any chip interaction.

The live face (DG2 portrait from the chip vs. the GPA capture) and the document authenticity (Passive/Active Authentication) together answer the two questions an issuer must answer before minting person-identification data: **is the document genuine**, and **is the person presenting it the document's subject, live and present**.

6 · Security properties

Property	How it is enforced
Holder-key binding	The PID's <code>cnf</code> is the wallet's P-256 JWK, registered at session creation. Only that wallet's key can later present the credential.
Session binding & anti-replay	A per-session nonce and the target holder-key thumbprint + audience are welded into the eMRTD attestation and checked by the issuer.
Genuine companion	The evidence submission carries an App Attest assertion bound to the request body, so VCissuer can require a real, registered PID Capture instance.
Authoritative validation	Liveness (iProov, S2S) and Passive Authentication are re-run at the issuer , downgrade-closed. The client is never trusted to decide.
Short-lived sessions	A capture session accepts evidence for 900 s , then must be recreated.
Verified issuance gate	The signing decision is a pure Rust kernel mirrored by a Lean 4 model and Tamarin lemmas; only the kernel can authorize a signature. An optional hybrid ES256 + ML-DSA-65 (post-quantum) wrapper is available.

7 · App Clip & universal-link mechanics

PID Capture claims `applinks:pid.advatar.systems` (and `appclips:pid.advatar.systems`). The `pid.advatar.systems` edge serves the Apple App Site Association at `/.well-known/apple-app-site-association` for app id `L2AF8KFX35.eu.advatar.wallet.pidcapture` (and `.Clip`), so opening `https://pid.advatar.systems/pid-capture?session=...` launches the installed app — or an **App Clip** with no App Store install. The same host reverse-proxies the capture API (`/v1/pid-capture/*`) to the issuer, so the companion resolves everything from one origin.

App
Full PID Capture install; universal link opens it directly.

App Clip
Instant, install-free; links only
CaptureKit to stay under Apple's 15 MB budget.

Cross-device
A wallet on another device polls the session and receives the PID by credential offer.

Advatar EUDI Wallet — Cross-Wallet PID Issuance via App Clip. Endpoints: `POST /v1/pid-capture/session`, `GET /v1/pid-capture/{id}`, `POST /v1/pid-capture/{id}/evidence`. Credential configuration `eu.europa.ec.eudi.pid_vc_sd_jwt.de` · format `dc+sd-jwt`. Device screens are representative mockups; home screen and QR are live output.